

Politique de Confidentialité

Summary AI — Bot Discord d'IA de résumé — Conformité RGPD

2026-05-15

Contents

1. Identité du responsable de traitement	2
2. Catégories de données traitées	2
3. Finalités et bases légales	2
4. Sous-traitants et transferts	3
5. Vos droits	3
Droit d'accès (art. 15)	3
Droit à l'effacement / droit à l'oubli (art. 17)	3
Droit d'opposition (art. 21)	3
Droit à la portabilité (art. 20)	4
Droit de rectification (art. 16)	4
Droit de réclamation	4
6. Sécurité	4
7. Auto-cleanup et durées de conservation	4
8. Mineurs	4
9. Notification de violation	5
10. Modifications	5
11. Désanonymisation et isolation de la base de données	5
11.1. Anonymisation par défaut	5
11.2. Mode pseudos réels (opt-in admin)	5
11.3. Opposition individuelle	5
11.4. Isolation de la base de données	5
12. Contact et exercice des droits	6

1. Identité du responsable de traitement

Charles Bentley, ci-après « l'Opérateur », est responsable du traitement des données personnelles collectées via le bot Summary AI au sens du Règlement (UE) 2016/679 (« RGPD »).

- E-mail : **charlesbentleypro@gmail.com**
- E-mail RGPD dédié : **charlesbentleypro+rgpd@gmail.com**
- Adresse postale : **Buc 78530, France**

2. Catégories de données traitées

Catégorie	Données	Source	Durée de conservation
Identifiants Discord	user_id, guild_id, channel_id (numériques)	Discord	Tant que l'utilisateur/serveur reste actif
Compteurs d'usage	Crédits consommés (à vie / mensuel)	Bot	24 mois après dernier usage
Logs d'audit	Date, salon, taille du résumé, tier de licence	Bot	12 mois
Cache de tuiles (anonymisé)	Résumés partiels de 3 heures, sans pseudos	Bot	7 jours
Cache de tuiles (pseudos réels)	Résumés partiels contenant des pseudos Discord, uniquement si l'admin du serveur a activé l'option	Bot	24 heures (TTL réduit)
Cache final	Résumés complets servis	Bot	1 heure
Pseudos Discord (display_name)	Uniquement si l'admin a activé use_real_names ET que le membre n'a pas opt-out via /optout option 1	Discord	Présent dans le cache tuile (24h max)
Préférences opt-out	4 flags + scope (serveur ou global)	Bot	Tant que l'utilisateur reste actif
Licences	Tier, dates, identifiants Discord d'entitlement	Discord Monetization	Durée + 12 mois
Cycle de vie du bot	Date d'invitation / retrait par serveur	Bot	30 jours après retrait

Important : les **messages Discord** transmis pour génération de résumés ne sont **jamais stockés** par l'Opérateur. Ils sont transmis à OpenAI le temps du traitement, puis purgés. Seuls les résumés générés (textes synthétiques) peuvent être mis en cache temporairement (cf. tableau).

3. Finalités et bases légales

Finalité	Base légale RGPD
Génération de résumés à la demande	Exécution du contrat (art. 6.1.b)
Comptage des crédits et facturation	Exécution du contrat (art. 6.1.b)
Cache pour réduire les coûts	Intérêt légitime (art. 6.1.f)
Logs d'audit et lutte contre l'abus	Intérêt légitime (art. 6.1.f)
Respect des obligations légales	Obligation légale (art. 6.1.c)

4. Sous-traitants et transferts

Sous-traitant	Rôle	Localisation	Garanties
OpenAI, L.L.C.	Génération du résumé (gpt-4o-mini)	États-Unis	Clauses Contractuelles Types UE-US, OpenAI DPA, store=false (aucune persistance ni réentraînement)
Discord Inc.	Plateforme et paiements	États-Unis	CCT, EU-US Data Privacy Framework

L'envoi des messages à OpenAI est nécessaire à l'exécution du service. Avant transmission, les messages sont **sanitisés** : emails, téléphones, URLs, mentions Discord et secrets détectables sont remplacés par des marqueurs [email], [téléphone], [lien], @membre, [secret]. Les identifiants des participants sont **anonymisés** en Membre 1, Membre 2, etc. — l'IA ne voit jamais les vrais pseudos.

5. Vos droits

Conformément aux articles 15 à 22 du RGPD, vous disposez des droits suivants :

Droit d'accès (art. 15)

Sur demande écrite à **charlesbentleypro+rgpd@gmail.com**, vous recevez sous 30 jours une copie au format JSON de toutes les données stockées sur vous.

Droit à l'effacement / droit à l'oubli (art. 17)

Commande Discord /**optout** -> cocher "Fully exclude my messages from AI processing" + sélectionner le scope.

Sur demande écrite, suppression complète de toutes les données (compteurs d'usage, audit logs, préférences) sous 30 jours.

Droit d'opposition (art. 21)

Commande Discord /**optout** : 4 niveaux disponibles dont seul le niveau 4 est actif en v1 (les autres sont prévus pour v2). Choix du scope (ce serveur seulement / tous les serveurs).

Droit à la portabilité (art. 20)

Sur demande écrite : copie JSON structurée de vos données sous 30 jours.

Droit de rectification (art. 16)

Sur demande écrite à charlesbentleypro+rgpd@gmail.com.

Droit de réclamation

Vous pouvez introduire une réclamation auprès de la **CNIL** (3 Place de Fontenoy, 75007 Paris) ou auprès de l'autorité de contrôle de votre pays de résidence dans l'UE.

6. Sécurité

L'Opérateur met en œuvre :

- chiffrement des communications (TLS 1.2+) avec Discord et OpenAI ;
- stockage de la clé API OpenAI en variable d'environnement, jamais dans le code source ni dans un dépôt git public ;
- accès à la base de données restreint à l'Opérateur ;
- **encapsulation XML stricte** des messages utilisateurs pour prévenir les attaques de prompt injection (toute instruction trouvée dans <transcript> est ignorée par l'IA) ;
- **détection automatique** de sortie suspecte avec alerte dans le salon de logs admin configuré ;
- logs d'audit pour détecter les abus ;
- paramètre OpenAI store=false : pas de persistance ni de réentraînement.

7. Auto-cleanup et durées de conservation

Une tâche automatique s'exécute toutes les 6 heures et purge :

- les tuiles de cache de plus de 7 jours ;
- les résumés finaux de cache de plus de 1 heure ;
- les compteurs d'usage de plus de 24 mois ;
- les logs d'audit de plus de 12 mois.

Lorsque le bot est retiré d'un serveur, les données associées sont conservées **30 jours** au cas où il serait réinvité, puis purgées automatiquement.

8. Mineurs

Discord requiert un âge minimum de 13 ans (16 ans dans certains pays UE). L'Opérateur ne traite pas sciemment de données de mineurs sous cet âge. En cas de signalement, les données sont supprimées sans délai.

9. Notification de violation

En cas de violation susceptible d'engendrer un risque pour les droits et libertés des personnes, l'Opérateur notifie la CNIL dans les 72 heures (art. 33) et informe les personnes concernées si le risque est élevé (art. 34).

10. Modifications

La présente politique peut être modifiée. Les modifications substantielles sont notifiées 15 jours avant leur entrée en vigueur via le serveur Discord de support et le dépôt public du bot.

11. Désanonymisation et isolation de la base de données

11.1. Anonymisation par défaut

Par défaut, l'IA reçoit les messages attribués à Membre 1, Membre 2, etc. Aucun pseudo Discord n'est transmis. C'est la configuration **privacy by design** au sens de l'article 25 du RGPD.

11.2. Mode pseudos réels (opt-in admin)

L'administrateur d'un serveur peut activer l'usage des pseudos Discord dans les résumés. Cette activation :

- nécessite une confirmation explicite (saisie de "ACTIVER")
- déclenche une **annonce automatique** dans le salon de logs configuré
- **réduit la durée de cache** des résumés contenant des pseudos à 24 heures
- est tracée dans la base de données avec l'horodatage et l'identifiant de l'admin qui a activé

11.3. Opposition individuelle

Tout membre peut s'opposer à l'usage de son pseudo via `/optout option 1` (*Hide my name in AI summaries*), même si l'admin a activé les pseudos réels. L'opposition s'applique au scope choisi (ce serveur ou tous les serveurs).

L'opposition via `/optout option 4` (*Fully exclude*) remplace les messages du membre par [OPT-OUT USER N] dans tous les résumés, indépendamment des autres paramètres.

11.4. Isolation de la base de données

L'Opérateur garantit que :

- **les administrateurs des serveurs n'ont aucun accès à la base de données du bot** ;
- les commandes Discord (`/credits`, `/setup`, `/optout`, etc.) ne donnent accès qu'à la configuration du serveur ou aux données personnelles du membre qui invoque la commande ;
- aucune commande Discord ne permet à un admin de consulter les compteurs d'usage, les résumés, ou les logs d'audit d'un autre membre ;
- seul l'Opérateur (responsable de traitement) a un accès technique direct à la base de données, dans le respect strict de l'article 32 du RGPD.

Cette isolation est un engagement contractuel de l'Opérateur. Les sous-traitants techniques (OpenAI, Discord) ne reçoivent que les données strictement nécessaires à l'exécution du service.

12. Contact et exercice des droits

- E-mail RGPD dédié : **charlesbentleypro+rgpd@gmail.com**
- Serveur Discord de support : **<https://discord.gg/> (en cours de création - sera communiqué prochainement)**

L'Opérateur s'engage à répondre sous 30 jours.